ou modifier la commande à notre avantage. Des listes complètes d'opérateurs d'injections sont évidemment accessibles sur internet.
Si des entrées ne match pas avec le format requis toujours vérifier si la vérification n'est pas effectuée côté front-end.

Quelques Opérateurs D'Injection :

Quelques exemples basiques :
Injection SQL : ' , ; -- /**/
Injections de Commandes : ; && ||
Injection LDAP : * ( ) & |
Injection de Code : ' ; -- /**/ $() ${} #{} %{} ^
(Il en existe bien sur des dizaines d'autres, injection d'object, XQuery, XPath, SSI code, d'entités, etc)...

Les Sécurité et Filtrage :

De nombreuses fonctionnalités peuvent sécuriser un application web contre ce type d'attaques. Tout d'abord on a le par-feu WAF qui analyse les requête et bloque les malveillantes.
Une application web peu également intégrer une liste de caractère en liste noir si la requête les contient elle sera refusée...
Le but sera évidemment de trouver quel caractère pass les filtres est exécuté la commande souhaité, et pour ce faire il faut être malin.
Par exemple si le caractère espace est sur blacklist on peu le remplacer par %09 qui est une tabulation ou encore ${IFS} car la valeur par défault de cette variable d'environnement Linux est une tabulation...
Je le répète on a toujours la référence PayloadAllTheThings.
Ou encore un slash par le début de la variable d'environnement PATH : ${PATH:0} Il y a plusieurs variables d'environnement qui peuvent être utilisées pour ça par exemple pour obtenir un point virgule ${LS_COLORS:10:1}, on saute 10 caractère et on en extrait 1, là ;...
Ici pour récupérer un \ je dit à windows de sélectionner la variable d'environnement d'avancer de 6 caractère et d'en enlever 11 depuis la fin : %HOMEPATH:~6,-11% pour cmd et pour powershell $env:HOMEPATH[6], on peu aussi choisir un caractère et injecter un opérateur de décalage de caractère pour retrouver le caractère que l'on souhaite injecter...

- Il existe une autre sécurité les listes noires de commandes qui bloquent les entrés utilisateurs dès qu'elles correspondent exactement à une commande system comme 'whoami' ou 'cat'.
Une des technique pour y échapper est d'y injecter des caractère non pris en compte par le terminal, par exemple avec bash on peu mettre des guillemets simples ou doubles pourvue que l'on ne mélange pas les deux et que leurs nombres soit paire, exemple : w'h'o'a'm'i ou encore : w""o""a""m""i, pour Linux on a encore $@ ou l'antislash \
Pour windows seulement on a le caractère ^

- On a quelques techniques d'évasion plus avancée comme utiliser la casse pour les commandes CMD et Powershell. WhOAmI
Sur du Linux on peu faire pareil en utilisant tr pour remplacer les caractères majuscules par des minuscules, Exemple : $(tr "[A-Z]" "[a-z]"<<<"WHOAMI")
On a l'inversion de commande pour retrouver la commande original que l'on veut faire passer : $(rev<<<'imaohw') La même chose peux être fais sous windows : iex "$('imaohw'[-1..-20] -join '')"
On peu également encodé la commande en b64 et la passé dans un sous shell qui la passera à bash : bash <<< $(base64 -d <<< blaB64commande)
La même chose est possible sur windows avec sa syntaxe cars couille.